

Đặc tả thiết kế phần mềm YouTube Learning Companion

Phục vụ triển khai nội bộ và báo cáo quản lý

Thuộc tính	Giá trị
Tên hệ thống	YouTube Learning Companion
Loại tài liệu	Software Design Specification
Phiên bản	1.0
Ngày ban hành	05/09/2026
Đơn vị lập	Nhóm dự án YouTube Learning Companion
Trạng thái	Baseline đề xuất để triển khai và phê duyệt

Tài liệu này xác định thiết kế mục tiêu cho Chrome Extension hỗ trợ học tập trên YouTube. Thiết kế ưu tiên một luồng MVP có thể kiểm chứng từ đăng nhập Google đến hỏi đáp kèm timestamp, đồng thời giữ OAuth token ngoài backend và không đọc cookie Google AI Studio.

Kiểm soát tài liệu

Phiên bản	Ngày	Nội dung	Trạng thái
1.0	05/09/2026	Baseline thiết kế hệ thống, dữ liệu, API, AI, bảo mật, kiểm thử và triển khai	Đề xuất phê duyệt

Tóm tắt điều hành

YouTube Learning Companion bổ sung một sidebar trên trang YouTube để người dùng tóm tắt video, xem chapter, tìm kiếm transcript, hỏi đáp với nội dung video, lưu ghi chú và tạo công cụ ôn tập. Sản phẩm giữ YouTube làm môi trường sử dụng chính và không thay thế nền tảng xem video.

Baseline kỹ thuật sử dụng React và TypeScript cho Chrome Extension Manifest V3, FastAPI cho backend, MySQL cho dữ liệu nghiệp vụ, ChromaDB cho vector search và Sentence Transformers cục bộ cho embedding. Gemini là dịch vụ sinh nội dung duy nhất. Extension lấy OAuth token bằng Chrome Identity API và gọi Gemini trực tiếp; backend không lưu hoặc ghi log token này.

Trước khi triển khai đầy đủ các chức năng AI, nhóm phải hoàn thành ba thử nghiệm bắt buộc: lấy transcript có timestamp, điều khiển YouTube Player và xác nhận cơ chế OAuth cùng quota Gemini trên nhiều tài khoản. Nếu một thử nghiệm không đạt, kiến trúc liên quan phải được cập nhật qua quyết định thiết kế có review.

Các quyết định cần phê duyệt

Mã	Quyết định	Đề xuất	Điều kiện
D01	Phạm vi MVP	OAuth, Video ID, timestamp, transcript, summary, chapter, search, Ask Video và bookmark	Quiz, flashcard và history triển khai sau MVP
D02	Xác thực Gemini	Google OAuth qua chrome.identity	Không đọc cookie AI Studio và không nhúng API key
D03	Vector search	Sentence Transformers cục bộ và ChromaDB	Chốt model sau benchmark tiếng Việt và tiếng Anh
D04	Xử lý nền	Worker đọc processing_jobs từ MySQL	Đủ cho MVP; đánh giá queue chuyên dụng khi tăng tải
D05	Bảo quản token	Token Gemini chỉ tồn tại trong Chrome token cache	Backend không nhận và không lưu token Gemini

Mục lục nội dung

Mục	Nội dung
1	Mục đích và phạm vi
2	Mục tiêu thiết kế và ràng buộc
3	Yêu cầu hệ thống
4	Kiến trúc tổng thể
5	Thiết kế Chrome Extension
6	Thiết kế Backend
7	Thiết kế AI và RAG
8	Thiết kế dữ liệu

Mục	Nội dung
9	Thiết kế API
10	Xác thực và bảo mật
11	Luồng xử lý chính
12	Xử lý lỗi và trạng thái
13	Triển khai và vận hành
14	Kiểm thử và nghiệm thu
15	Rủi ro và quyết định mở
16	Phân công và kế hoạch bàn giao
17	Tài liệu tham khảo

1 Mục đích và phạm vi

1 1 Mục đích

SDS này mô tả cấu trúc phần mềm, trách nhiệm của từng thành phần, mô hình dữ liệu, hợp đồng API, luồng AI, kiểm soát bảo mật và tiêu chí kiểm thử của YouTube Learning Companion. Nhóm phát triển dùng tài liệu làm baseline triển khai; quản lý dùng tài liệu để xem xét phạm vi, rủi ro và điều kiện nghiệm thu.

1 2 Phạm vi trong phiên bản đầu

- Nhận diện video YouTube hiện tại và theo dõi thay đổi khi trang điều hướng theo kiểu SPA.
- Hiện thị sidebar, đọc thời gian hiện tại và chuyển player đến timestamp được chọn.
- Thu thập, làm sạch, chia chunk và lập chỉ mục transcript.
- Tạo summary, chapter, concept, tìm kiếm ngữ nghĩa và Ask Video kèm timestamp.
- Lưu bookmark và các dữ liệu học tập được đưa vào phạm vi sprint đã phê duyệt.
- Đăng nhập Google bằng OAuth và sử dụng Gemini mà không nhúng API key trong extension.

1 3 Phạm vi ngoài phiên bản đầu

- Tổng hợp kiến thức từ nhiều video và phân tích điểm kiến thức còn yếu.
- Đề xuất video tự động, mạng xã hội, thanh toán và ứng dụng mobile.
- Thay thế YouTube bằng một nền tảng học tập độc lập.
- Đảm bảo xử lý được video không có transcript hoặc video bị giới hạn quyền truy cập.

1 4 Thuật ngữ

Thuật ngữ	Định nghĩa
SDS	Software Design Specification, tài liệu đặc tả thiết kế phần mềm
MVP	Phiên bản nhỏ nhất có thể trình diễn và nghiệm thu luồng chính
Transcript	Nội dung lời nói của video kèm mốc thời gian
Chunk	Đoạn transcript được chia nhỏ để lập chỉ mục và truy xuất
Embedding	Vector biểu diễn ngữ nghĩa của chunk hoặc câu hỏi
RAG	Luồng truy xuất các chunk liên quan trước khi yêu cầu mô hình tạo câu trả lời
Citation	Tham chiếu từ câu trả lời tới đoạn transcript và timestamp
OAuth token	Thông tin ủy quyền ngắn hạn do Google cấp cho extension

2 Mục tiêu thiết kế và ràng buộc

2 1 Mục tiêu thiết kế

- Kết quả AI phải có thể kiểm chứng bằng transcript và timestamp.
- Extension phải chịu được việc người dùng chuyển video mà YouTube không reload toàn bộ trang.
- Backend phải xử lý idempotent để một video không tạo nhiều job trùng lặp.
- Token Gemini không đi qua backend và không xuất hiện trong dữ liệu lưu trữ hoặc log.
- Các module phải giao tiếp qua schema ổn định để bốn thành viên có thể phát triển song song.
- MVP phải chạy được trên môi trường demo với quy trình cài đặt có thể lặp lại.

2 2 Ràng buộc

Nhóm	Ràng buộc thiết kế
------	--------------------

Nhóm	Ràng buộc thiết kế
Nền tảng	Chrome Extension Manifest V3 hoạt động trên trang YouTube
AI	Chỉ sử dụng Gemini cho sinh nội dung; không dùng key của OpenAI, Claude hoặc provider khác
Xác thực	Sử dụng Google OAuth; không đọc hoặc tái sử dụng cookie AI Studio
Backend	Python, FastAPI và REST API
Dữ liệu	MySQL lưu dữ liệu nghiệp vụ; ChromaDB lưu vector và metadata liên quan
Bảo mật	Không lưu password, cookie hoặc Gemini access token
Phạm vi	Ưu tiên luồng MVP trước các chức năng quiz, flashcard và learning history

2.3 Giải định

- Người dùng sử dụng Chrome và chủ động mở extension trên trang video YouTube.
- Video có transcript hợp lệ thì mới được đưa vào pipeline AI.
- Mỗi video được định danh bằng YouTube Video ID và có thể được nhiều người dùng tham chiếu.
- Môi trường triển khai backend hỗ trợ HTTPS, MySQL và lưu trữ bền vững cho ChromaDB.
- Mô hình embedding đa ngôn ngữ được chọn sau khi benchmark bộ dữ liệu tiếng Việt và tiếng Anh.

3 Yêu cầu hệ thống

3.1 Yêu cầu chức năng

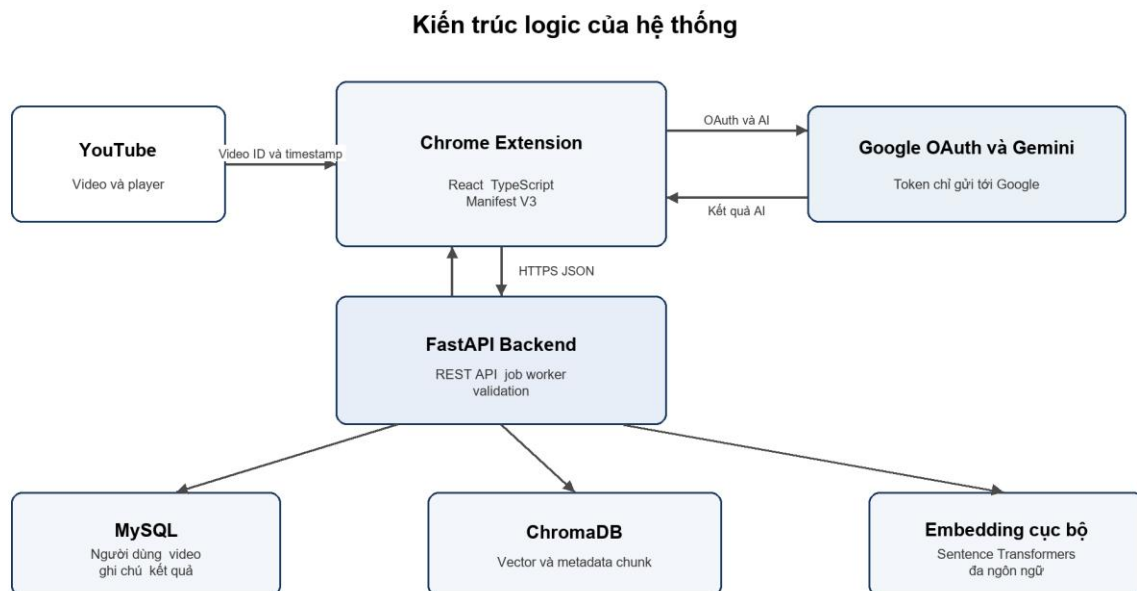
Mã	Chức năng	Yêu cầu	Ưu tiên
FR01	Đăng nhập Google	Extension kiểm tra token im lặng và chỉ mở OAuth sau thao tác của người dùng	MVP
FR02	Nhận diện video	Lấy Video ID, tiêu đề và phát hiện thay đổi video	MVP
FR03	Điều khiển thời gian	Đọc timestamp hiện tại và seek đến timestamp được chọn	MVP
FR04	Thu thập transcript	Lấy transcript, ngôn ngữ và timestamp nguồn	MVP
FR05	Xử lý transcript	Làm sạch, gộp segment, chia chunk và lưu metadata	MVP
FR06	Tạo summary	Sinh tóm tắt bám sát transcript	MVP
FR07	Tạo chapter	Sinh chapter theo thứ tự và kèm timestamp	MVP
FR08	Nhận diện concept	Tạo danh sách khái niệm và timestamp nguồn	Sau MVP
FR09	Tìm kiếm	Tìm kiếm từ khóa và ngữ nghĩa trong transcript	MVP
FR10	Ask Video	Trả lời dựa trên context truy xuất và kèm citation	MVP
FR11	Bookmark	Lưu đoạn quan trọng tại timestamp hiện tại	MVP
FR12	Notes	Tạo, sửa, xóa và xem ghi chú theo video	Sau MVP
FR13	Quiz	Sinh câu hỏi, đáp án, giải thích và timestamp	Sau MVP
FR14	Flashcard	Sinh và lưu thẻ hỏi đáp từ transcript	Sau MVP
FR15	Learning History	Theo dõi video, quiz và hoạt động học tập	Sau MVP
FR16	Xử lý trạng thái	Hiển thị loading, retry, empty state và lỗi có hướng dẫn	MVP

3.2 Yêu cầu phi chức năng

Mã	Thuộc tính	Mục tiêu kiểm chứng
NFR01	Bảo mật	Không lưu Gemini token, cookie hoặc password; mọi kết nối backend dùng HTTPS
NFR02	Quyền tối thiểu	Manifest chỉ khai báo permission và host permission cần cho chức năng
NFR03	Hiệu năng giao diện	Thao tác mở sidebar và seek phản hồi trong khoảng một giây trên máy kiểm thử
NFR04	Hiệu năng dữ liệu	Kết quả đã cache trả về trong mục tiêu hai giây ở môi trường demo
NFR05	Hiệu năng search	Semantic search có mục tiêu phản hồi dưới ba giây với video đã lập chỉ mục
NFR06	Tin cậy	Job có trạng thái rõ ràng, timeout và retry có giới hạn
NFR07	Tính đúng AI	Câu trả lời ngoài transcript phải được từ chối hoặc đánh dấu không đủ dữ kiện
NFR08	Khả năng bảo trì	Module tách theo trách nhiệm; schema và prompt được version hóa
NFR09	Khả năng kiểm thử	Luồng MVP có unit, integration và end to end test
NFR10	Khả năng truy cập	Sidebar dùng được bằng bàn phím và có nhãn cho điều khiển
NFR11	Quan sát hệ thống	Log có request ID và job ID nhưng loại bỏ credential
NFR12	Tương thích	Hỗ trợ Chrome Stable trên môi trường được nhóm công bố

4 Kiến trúc tổng thể

Kiến trúc chia hệ thống thành ba vùng trách nhiệm. Chrome Extension quản lý giao diện, YouTube Player, Google OAuth và các request Gemini. FastAPI quản lý transcript, dữ liệu nghiệp vụ, job và search. MySQL cùng ChromaDB cung cấp lưu trữ bền vững cho dữ liệu quan hệ và vector.



Hình 1 Kiến trúc logic của YouTube Learning Companion

4.1 Trách nhiệm thành phần

Thành phần	Trách nhiệm	Không chịu trách nhiệm
Chrome Extension	UI, Video ID, timestamp, OAuth, gọi Gemini, trình bày citation	Không lưu dữ liệu quan hệ hoặc chạy vector search
FastAPI	API, validation, job, transcript, dữ liệu, context retrieval	Không lưu hoặc ghi log Gemini token

Thành phần	Trách nhiệm	Không chịu trách nhiệm
MySQL	Người dùng, video, transcript metadata, artifacts, notes, bookmark và job	Không lưu vector dung lượng lớn
ChromaDB	Vector chunk và metadata tối thiểu để truy xuất	Không làm nguồn dữ liệu nghiệp vụ chính
Embedding cục bộ	Tạo vector cho chunk và câu hỏi	Không sinh summary hoặc câu trả lời
Gemini	Sinh summary, chapter, concept, quiz, flashcard và câu trả lời	Không được coi là nguồn dữ liệu ngoài transcript

4.2 Cấu trúc kho mã nguồn

```

youtube-learning-companion/
|-- apps/extension/
|   |-- src/background/
|   |-- src/content/
|   |-- src/components/
|   |-- src/services/
|   `-- src/stores/
|-- services/api/
|   |-- app/api/
|   |-- app/models/
|   |-- app/schemas/
|   |-- app/services/
|   `-- app/jobs/
|-- packages/shared-types/
|-- docs/
`-- infra/

```

5 Thiết kế Chrome Extension

5.1 Thành phần nội bộ

Module	Chức năng chính	Đầu vào và đầu ra
Content Script	Theo dõi trang YouTube và cầu nối tới player	DOM và URL vào; Video ID và timestamp ra
YouTube Adapter	Chuẩn hóa phát hiện video, play state và seek	Player state vào; sự kiện chuẩn hóa ra
Background Service Worker	OAuth, network request, message routing	Message vào; token hoặc response ra
Sidebar App	Hiển thị summary, chapter, search, Ask Video và dữ liệu học tập	State và API data vào; thao tác người dùng ra
Auth Service	Quản lý state và vòng đời OAuth	User action vào; auth state ra
Gemini Client	Gửi prompt và validate response cơ bản	Context và token vào; JSON artifact ra
API Client	Gọi FastAPI và chuẩn hóa lỗi	Request typed vào; response typed ra

5 2 State của sidebar

```
BOOTSTRAPPING -> CHECKING_AUTH -> NEED_GOOGLE_LOGIN
                        -> AUTHORIZING
                        -> CHECKING_GEMINI_ACCESS
                        -> READY
READY -> VIDEO_LOADING -> VIDEO_READY | VIDEO_UNSUPPORTED | VIDEO_FAILED
READY -> TOKEN_EXPIRED | QUOTA_EXCEEDED | API_UNAVAILABLE
```

Mỗi lần YouTube chuyển video, extension phải hủy request hoặc poll của video cũ, xóa state phụ thuộc video, đọc Video ID mới và nạp lại trạng thái xử lý. Cơ chế này ngăn sidebar hiển thị nhầm summary hoặc citation của video trước.

5 3 Message contract

Message	Nguồn	Đích	Nội dung
VIDEO_CHANGED	Content Script	Sidebar	videoid, title, url
PLAYER_TIME_UPDATED	Content Script	Sidebar	currentTime
SEEK_TO	Sidebar	Content Script	targetTime
AUTH_CHECK	Sidebar	Service Worker	interactive false
AUTH_START	Sidebar	Service Worker	interactive true sau user gesture
GEMINI_REQUEST	Sidebar	Service Worker	operation, context, schemaVersion
AUTH_LOGOUT	Sidebar	Service Worker	xóa token cache và state phiên

6 Thiết kế Backend

6 1 Các lớp

Lớp	Trách nhiệm
API Router	Nhận request, xác thực session ứng dụng, gọi service và trả HTTP response
Schema	Validate request và response; tách schema API khỏi ORM model
Service	Thực hiện use case như analyze video, search, notes và bookmark
Repository	Đọc và ghi MySQL; không chứa business logic
Job Worker	Claim job, xử lý transcript, chunk, embedding và cập nhật trạng thái
Vector Adapter	Ghi và truy vấn ChromaDB bằng chunk_id
Error Mapper	Chuyển lỗi domain thành HTTP status và error code ổn định

6 2 Vòng đời job

1. POST videos analyze kiểm tra video và job hiện có.
2. Nếu artifact còn hợp lệ, backend trả trạng thái completed và dữ liệu cache.
3. Nếu chưa có, backend tạo một processing job với khóa chống trùng theo video và phiên bản pipeline.
4. Worker claim job bằng thao tác nguyên tử và chuyển trạng thái sang processing transcript.
5. Worker thu thập transcript, chuẩn hóa, chia chunk, tạo embedding và ghi vector.
6. Backend cập nhật completed khi index sẵn sàng hoặc failed cùng mã lỗi có thể hành động.

6 3 Idempotency và versioning

Khóa logic của một lần xử lý gồm video ID, transcript language và pipeline version. Request lặp lại với cùng khóa phải trả job đang chạy hoặc artifact hiện có. Khi thuật toán chunking, model embedding hoặc prompt schema thay đổi, nhóm tăng phiên bản tương ứng để tạo artifact mới mà không ghi đè dữ liệu cũ ngoài kiểm soát.

6 4 Quy ước lỗi API

```
{
  "error": {
    "code": "TRANSCRIPT_NOT_AVAILABLE",
    "message": "Video không có transcript phù hợp.",
    "retryable": false,
    "request_id": "req_01H..."
  }
}
```

7 Thiết kế AI và RAG

7 1 Pipeline transcript

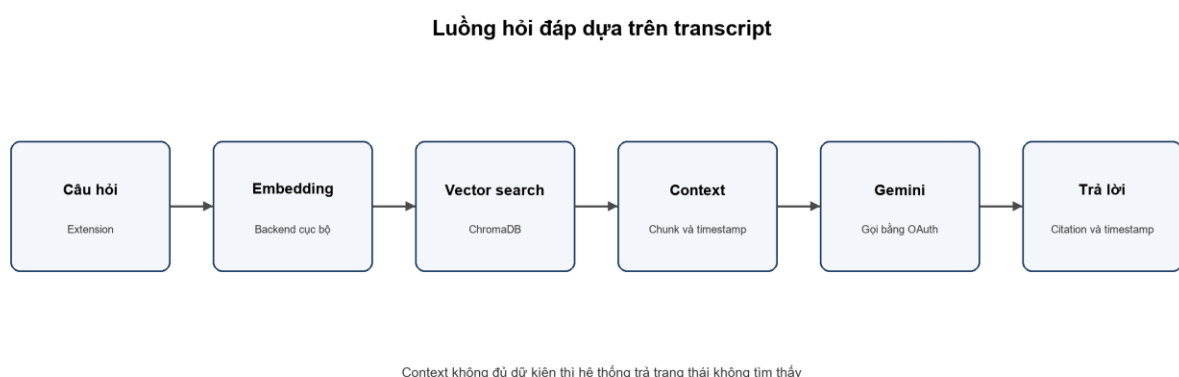
Transcript processor giữ nguyên thứ tự và timestamp nguồn. Pipeline loại bỏ khoảng trắng, chuẩn hóa ký tự, gộp segment quá ngắn trong một khoảng thời gian liên tục và chia chunk có overlap. Mỗi chunk lưu start time, end time, position, language và pipeline version.

Raw transcript -> Normalize -> Merge short segments -> Chunk with overlap
-> Attach timestamps -> Embed -> Store vector and metadata

7 2 Baseline embedding và vector search

MVP dùng Sentence Transformers đa ngôn ngữ chạy trong backend và lưu vector tại ChromaDB. Cách này không cần gửi OAuth token cho backend, đồng thời cho phép worker lập chỉ mục khi extension không mở. Model cuối cùng được chọn bằng benchmark tiếng Việt và tiếng Anh; thay đổi model phải tăng embedding version.

7 3 Luồng Ask Video



Hình 2 Luồng Ask Video dựa trên transcript

Backend chỉ trả các chunk liên quan. Extension xây prompt có giới hạn, gọi Gemini trực tiếp và validate response. Nếu điểm truy xuất thấp hoặc Gemini không thể dẫn nguồn hợp lệ, UI hiển thị trạng thái không tìm thấy nội dung thay vì đưa ra câu trả lời suy đoán.

7 4 Schema đầu ra AI

Artifact	Trường bắt buộc	Kiểm tra
Summary	summary, key_points, language, schema_version	Không rỗng và không chứa citation ngoài transcript
Chapter	title, summary, start_time, end_time	Có thứ tự, không vượt duration và không chồng chéo bất hợp lý
Concept	name, explanation, timestamps	Timestamp tồn tại trong transcript
Ask answer	answer, citations, grounded	Mỗi citation tham chiếu chunk và timestamp hợp lệ
Quiz	question, options, correct_answer, explanation, timestamp	Single choice chỉ có một đáp án đúng
Flashcard	front, back, timestamp	Không trùng nội dung trong cùng video

7 5 Prompt safety

- System instruction yêu cầu mô hình chỉ sử dụng context được cung cấp.
- Transcript được đánh dấu là dữ liệu không tin cậy và không được phép thay đổi instruction.
- Prompt giới hạn số chunk, tổng kích thước context và định dạng JSON đầu ra.
- Response phải được validate theo schema trước khi hiển thị hoặc lưu.
- Nội dung không đủ căn cứ phải trả về grounded false hoặc trạng thái không tìm thấy.

8 Thiết kế dữ liệu

8 1 Mô hình thực thể

Thực thể	Trường chính	Vai trò và quan hệ
users	id, google_sub, email, created_at	Chủ sở hữu notes, bookmarks và history
videos	id, youtube_video_id, title, duration, status	Nguồn chung cho transcript và artifact
transcripts	id, video_id, language, source, version	Một video có thể có nhiều ngôn ngữ hoặc phiên bản
transcript_chunks	id, transcript_id, text, start_time, end_time, position	Metadata chuẩn; vector lưu tại ChromaDB
chapters	id, video_id, title, summary, start_time, end_time, version	Kết quả AI đã validate
concepts	id, video_id, name, explanation, timestamps	Khái niệm và nguồn kiểm chứng
processing_jobs	id, video_id, pipeline_version, status, error_code	Theo dõi và chống job trùng
notes	id, user_id, video_id, timestamp, content	Ghi chú riêng của người dùng
bookmarks	id, user_id, video_id, timestamp, label	Đánh dấu đoạn quan trọng
quizzes	id, user_id, video_id, schema_version	Nhóm câu hỏi được sinh
quiz_questions	id, quiz_id, question, options, answer, explanation	Nội dung câu hỏi và kết quả
flashcards	id, user_id, video_id, front, back, timestamp	Thẻ ôn tập
learning_history	id, user_id, video_id, action, occurred_at	Dòng sự kiện học tập

8 2 Quy tắc dữ liệu

- youtube_video_id là duy nhất trong bảng videos.
- position của chunk là duy nhất trong phạm vi một transcript version.

- start_time không âm và end_time phải lớn hơn hoặc bằng start_time.
- Mỗi vector lưu chunk_id, embedding_version và video_id để kiểm tra chéo.
- Xóa dữ liệu người dùng phải xử lý notes, bookmarks, quizzes, flashcards và history theo chính sách đã phê duyệt.
- Không lưu OAuth token, Google password hoặc cookie trong bất kỳ bảng nào.

8 3 Trạng thái job

Trạng thái	Ý nghĩa	Chuyển tiếp hợp lệ
pending	Job đã tạo và chờ worker	processing_transcript hoặc failed
processing_transcript	Đang lấy và chuẩn hóa transcript	generating_embeddings hoặc failed
generating_embeddings	Đang tạo và lưu vector	completed hoặc failed
completed	Index đã sẵn sàng	Không chuyển tiếp; tạo job version mới nếu cần
failed	Job dừng với error_code	pending khi retry hợp lệ

9 Thiết kế API

9 1 Nguyên tắc

- API dùng JSON và đường dẫn có tiền tố phiên bản, ví dụ api v1.
- Backend session xác định người dùng; Gemini access token không gửi vào FastAPI.
- Mọi response lỗi dùng error code ổn định và request ID.
- Các endpoint tạo dữ liệu phải validate ownership và giới hạn kích thước input.
- Schema dùng chung được phát hành trong packages shared types hoặc sinh từ OpenAPI.

9 2 Danh sách endpoint

Phương thức	Đường dẫn	Mục đích	Quyền
POST	/api/v1/auth/google/exchange	Đổi Google ID token thành session ứng dụng; không nhận Gemini token	Public
POST	/api/v1/auth/logout	Thu hồi session ứng dụng	User
POST	/api/v1/videos/analyze	Tạo hoặc lấy job xử lý video	User
GET	/api/v1/videos/{id}/status	Đọc trạng thái job và progress	User
GET	/api/v1/videos/{id}/summary	Đọc summary đã lưu	User
GET	/api/v1/videos/{id}/chapters	Đọc chapter	User
GET	/api/v1/videos/{id}/concepts	Đọc concept	User
GET	/api/v1/videos/{id}/context	Lấy context cho một AI operation	User
POST	/api/v1/videos/{id}/artifacts	Lưu artifact AI đã validate	User
POST	/api/v1/videos/{id}/search	Tìm kiếm keyword và vector	User
POST	/api/v1/videos/{id}/ask/context	Truy xuất chunk cho Ask Video	User
GET POST	/api/v1/videos/{id}/bookmarks	Đọc hoặc tạo bookmark	Owner
DELETE	/api/v1/bookmarks/{id}	Xóa bookmark	Owner
GET POST	/api/v1/videos/{id}/notes	Đọc hoặc tạo note	Owner
PUT DELETE	/api/v1/notes/{id}	Sửa hoặc xóa note	Owner
POST	/api/v1/videos/{id}/quiz	Lưu quiz đã sinh	Owner

Phương thức	Đường dẫn	Mục đích	Quyền
POST	/api/v1/videos/{id}/flashcards	Lưu flashcard đã sinh	Owner
GET	/api/v1/learning-history	Đọc lịch sử học tập	Owner

9 3 Ví dụ Ask Video context

```
{
  "question": "JWT được giải thích ở phần nào?",
  "top_k": 5,
  "language": "vi"
}

{
  "video_id": "internal_uuid",
  "chunks": [
    {"chunk_id": "c12", "text": "...", "start_time": 320, "end_time": 356, "score": 0.84}
  ],
  "retrieval_version": "1"
}
```

10 Xác thực và bảo mật

10 1 Luồng Google OAuth

Luồng đăng nhập và kiểm tra quyền Gemini



Extension không đọc cookie AI Studio và không lưu access token trong MySQL hoặc log

Hình 3 Luồng đăng nhập và kiểm tra quyền Gemini

Extension gọi `chrome.identity.getToken` với `interactive false` khi mở sidebar. Khi cần đăng nhập hoặc cấp quyền, UI giải thích mục đích và chỉ gọi `interactive true` sau thao tác của người dùng. Token lỗi được xóa khỏi Chrome token cache trước khi xin token mới.

10 2 Tách danh tính ứng dụng và quyền Gemini

Danh tính dùng cho dữ liệu người dùng và quyền gọi Gemini là hai mối quan tâm riêng. Backend chỉ nhận Google ID token trong luồng đăng nhập ứng dụng, xác minh issuer, audience và thời hạn, sau đó phát hành session của hệ thống. Gemini access token chỉ được extension gửi tới endpoint chính thức của Google.

10 3 Kiểm soát bảo mật

Vùng	Kiểm soát
Token	Không lưu Gemini token trong localStorage, MySQL hoặc log; xóa cache khi logout hoặc 401

Vùng	Kiểm soát
Cookie	Không khai báo cookies permission và không đọc cookie AI Studio
Transport	FastAPI chỉ phục vụ HTTPS trong môi trường dùng chung
CORS	Chỉ cho phép extension ID và origin quản trị đã cấu hình
Authorization	Notes, bookmark, quiz, flashcard và history kiểm tra ownership
Input	Giới hạn kích thước câu hỏi, note và transcript; validate kiểu và phạm vi timestamp
Logging	Mask Authorization header, token, email khi không cần và nội dung nhạy cảm
Prompt injection	Coi transcript là dữ liệu không tin cậy và không cho phép thay đổi instruction
Secrets	Secret backend đặt trong secret manager hoặc biến môi trường, không commit vào Git

10 4 Quyền extension

Baseline manifest chỉ yêu cầu identity, storage, sidePanel hoặc scripting tùy cách cài sidebar, cùng host permission giới hạn cho youtube.com, backend của dự án và generativelanguage.googleapis.com. Mọi quyền bổ sung phải có lý do, người review và test quyền tối thiểu.

11 Luồng xử lý chính

11 1 Phân tích video

- Content Script phát hiện Video ID và thông báo cho sidebar.
- Sidebar gọi videos analyze. Backend trả artifact cache hoặc job ID.
- Worker lấy transcript, chuẩn hóa, chia chunk, tạo embedding và ghi vector.
- Sidebar poll trạng thái cho đến khi index hoàn thành hoặc job thất bại.
- Sidebar lấy context cần thiết, gọi Gemini trực tiếp và validate JSON trả về.
- Extension hiển thị artifact và có thể lưu bản đã validate qua artifacts endpoint.

11 2 Tìm kiếm và chuyển timestamp

- Người dùng nhập từ khóa hoặc câu hỏi ngắn.
- Backend thực hiện keyword search và vector search, sau đó hợp nhất kết quả.
- API trả chunk, score và timestamp.
- Sidebar hiển thị kết quả; click timestamp gửi SEEK_TO cho Content Script.
- YouTube Adapter điều khiển player và trả state mới cho sidebar.

11 3 Ask Video

- Sidebar gửi câu hỏi tới ask context endpoint.
- Backend embedding câu hỏi và truy xuất top k chunk có score đạt ngưỡng.
- Nếu không có context đủ tốt, backend trả found false.
- Nếu có context, extension xây prompt và gọi Gemini bằng OAuth token.
- Extension validate citation, hiển thị câu trả lời và cho phép nhảy đến timestamp.

11 4 Notes và bookmark

- Sidebar lấy timestamp hiện tại từ YouTube Adapter.
- Người dùng nhập label hoặc note và xác nhận lưu.
- Backend kiểm tra session, quyền sở hữu, video và phạm vi timestamp.
- MySQL lưu dữ liệu; API trả bản ghi đã tạo để sidebar cập nhật ngay.

12 Xử lý lỗi và trạng thái

Mã lỗi	HTTP	Điều kiện	Hành vi UI
AUTH_REQUIRED	401	Chưa có session ứng dụng	Hiện màn hình đăng nhập
GEMINI_AUTH_REQUIRED	401 phía Google	Token Gemini thiếu hoặc hết hạn	Xóa token cache và yêu cầu đăng nhập lại
GEMINI_PERMISSION_DENIED	403	Tài khoản hoặc project thiếu quyền	Hiện hướng dẫn hoàn tất thiết lập
QUOTA_EXCEEDED	429	Hết quota Gemini	Thông báo và cho phép thử lại sau
TRANSCRIPT_NOT_AVAILABLE	422	Video không có transcript phù hợp	Dừng pipeline AI
VIDEO_UNSUPPORTED	422	Video riêng tư, giới hạn hoặc loại chưa hỗ trợ	Hiện lý do cụ thể
JOB_ALREADY_RUNNING	200 hoặc 409	Video đang được xử lý	Tiếp tục theo dõi job hiện có
AI_RESPONSE_INVALID	502	Gemini trả JSON sai schema	Retry có giới hạn hoặc yêu cầu tạo lại
VECTOR_STORE_UNAVAILABLE	503	ChromaDB không phản hồi	Ghi lỗi và cho phép retry
API_UNAVAILABLE	503	Backend hoặc Gemini gián đoạn	Giữ state và hiển thị retry

13 Triển khai và vận hành

13 1 Topology triển khai

- Chrome Extension được đóng gói riêng và cài bằng Developer Mode trong giai đoạn phát triển.
- FastAPI chạy sau reverse proxy HTTPS.
- Worker chạy thành process riêng và dùng cùng codebase với API.
- MySQL sử dụng volume bền vững và backup định kỳ theo môi trường.
- ChromaDB sử dụng volume bền vững; vector được tạo lại từ transcript khi cần.

13 2 Cấu hình môi trường

Biến	Mục đích	Bảo mật
APP_ENV	development, test hoặc production	Không bí mật
DATABASE_URL	Kết nối MySQL	Secret backend
CHROMA_PATH	Vị trí vector store	Không chứa token
EMBEDDING_MODEL	Tên và phiên bản model embedding	Không bí mật
ALLOWED_EXTENSION_IDS	Danh sách extension được phép gọi API	Cấu hình backend
SESSION_SIGNING_KEY	Ký session ứng dụng	Secret backend
LOG_LEVEL	Mức log theo môi trường	Không bí mật

13 3 Quan sát hệ thống

- Mỗi request có request ID; mỗi job có job ID dùng xuyên suốt log.
- Theo dõi số job pending, running, completed và failed.
- Theo dõi thời gian lấy transcript, chunking, embedding, search và AI request.
- Theo dõi tỷ lệ lỗi theo error code mà không ghi token hoặc nội dung nhạy cảm.

- Health endpoint kiểm tra API; readiness kiểm tra MySQL và ChromaDB.

14 Kiểm thử và nghiệm thu

14 1 Chiến lược kiểm thử

Loại	Phạm vi	Thời điểm
Unit	Video ID parser, timestamp, transcript cleaning, chunking, schema validation, error mapping	Mỗi PR
Integration	Extension và YouTube, OAuth và Gemini, FastAPI và MySQL, FastAPI và ChromaDB	Mỗi sprint
End to end	Đăng nhập, phân tích, summary, chapter, search, Ask Video và bookmark	Trước demo và release
Security	Permission, token leakage, ownership, CORS, input limits và log masking	Sprint 1 và Sprint 6
AI evaluation	Groundedness, citation, timestamp, câu hỏi ngoài video, tiếng Việt và tiếng Anh	Sprint 3 đến Sprint 6
Regression	Luồng MVP và các lỗi đã đóng	Trước merge release

14 2 Bộ dữ liệu kiểm thử

- Từ 10 đến 15 video gồm tiếng Việt, tiếng Anh, video ngắn, video dài, subtitle tự động và subtitle do tác giả cung cấp.
- Có video không transcript, video riêng tư hoặc bị giới hạn để kiểm tra lỗi.
- Mỗi video có câu hỏi dễ, trung bình, khó, câu hỏi cần timestamp và câu hỏi không có trong video.
- Expected result ghi rõ chunk hoặc khoảng timestamp dùng để đánh giá.

14 3 Điều kiện nghiệm thu MVP

Hạng mục	Điều kiện đạt
Đăng nhập	Người đã cấp quyền đi thẳng vào sidebar; người chưa cấp quyền chỉ thấy OAuth sau khi bấm nút
Video	Extension nhận đúng Video ID sau khi mở, reload và chuyển video
Timestamp	Click chapter, search result hoặc citation đưa player đến đúng vị trí
Transcript	Giữ đúng thứ tự và timestamp; video không transcript dừng pipeline có thông báo
Search	Trả chunk liên quan kèm score và timestamp trên bộ test đã thống nhất
Ask Video	Trả lời có citation hợp lệ và từ chối câu hỏi không có căn cứ
Backend	Không tạo job trùng; job lỗi có error code và retry theo chính sách
Bảo mật	Không phát hiện API key, Gemini token hoặc cookie trong source, build, database và log
Release	Không còn lỗi Critical hoặc High; hạn chế còn lại được ghi trong báo cáo

15 Rủi ro và quyết định mở

15 1 Rủi ro

Mã	Rủi ro	Mức	Giảm thiểu
R01	Không lấy được transcript ổn định	Cao	Prototype Sprint 1; hỗ trợ video có transcript; dừng AI khi

Mã	Rủi ro	Mức	Giảm thiểu
			thiếu dữ liệu
R02	OAuth hoặc quota Gemini không hoạt động như giả định	Cao	Test nhiều tài khoản và project trước khi xây chức năng AI
R03	YouTube thay đổi DOM hoặc player	Cao	Tách YouTube Adapter và có regression test
R04	Gemini bịa nội dung hoặc timestamp	Cao	RAG có threshold, schema validation và grounded false
R05	Service worker bị dừng khi AI request dài	Trung bình	Giới hạn request; kiểm thử thực tế; đánh giá kiến trúc server side nếu cần
R06	Video dài gây chậm	Trung bình	Chunking, cache, batch embedding và progress state
R07	ChromaDB hoặc model embedding khó triển khai	Trung bình	Đóng gói container và chuẩn bị quy trình rebuild index
R08	Rò rỉ token hoặc dữ liệu người dùng	Cao	Quyền tối thiểu, không lưu token, log masking và security test
R09	Phạm vi vượt khả năng 12 tuần	Cao	Khóa MVP; chuyển quiz, flashcard và history sang sau MVP
R10	Rủi ro điều khoản khi lấy transcript	Cao	Review phương án transcript trước triển khai và chỉ xử lý theo thao tác người dùng

15 2 Quyết định mở

Mã	Quyết định	Chủ trì	Hạn chót
O01	Cách lấy transcript hợp lệ và ổn định	AI/RAG và Backend	Cuối Sprint 1
O02	Quota Gemini thuộc project nào khi extension dùng OAuth	Frontend và QA	Cuối Sprint 1
O03	Model embedding đa ngôn ngữ	AI/RAG	Đầu Sprint 3
O04	Chính sách lưu và hết hạn transcript	Backend và quản lý	Trước Sprint 3
O05	Cách phát hành extension cho người dùng ngoài nhóm	Frontend và quản lý	Trước Sprint 6

16 Phân công và kế hoạch bàn giao

16 1 Trách nhiệm chính

Người	Vai trò	Trách nhiệm	Đầu ra
Thành viên 1	Extension Frontend	React, Manifest V3, sidebar, YouTube Adapter, OAuth UI và Gemini client	Bản extension load được và test UI
Thành viên 2	Backend	FastAPI, REST API, MySQL, job worker, cache, session và deployment	API, migration, OpenAPI và môi trường chạy
Thành viên 3	AI và RAG	Transcript, chunking, embedding, ChromaDB, search, prompt và evaluation	Pipeline AI, schema và báo cáo đánh giá
Thành viên 4	QA và Integration	Test plan, OAuth/security test, end to end, tài liệu, slide và demo	Test report và gói bàn giao

16 2 Ma trận phối hợp

Hạng mục	Chủ trì	Phối hợp
Sidebar và YouTube	Thành viên 1	Thành viên 4

Hạng mục	Chủ trì	Phối hợp
Google OAuth phía extension	Thành viên 1	Thành viên 4
Session và REST API	Thành viên 2	Thành viên 1 và 4
MySQL và job worker	Thành viên 2	Thành viên 3 và 4
Transcript và embedding	Thành viên 3	Thành viên 2
Prompt và RAG	Thành viên 3	Thành viên 1 và 4
Integration và release	Thành viên 4	Cả nhóm

16 3 Mốc bàn giao

Mốc	Đầu ra	Cổng kiểm soát
Tuần 2	OAuth, gọi Gemini, Video ID, timestamp và transcript prototype	Quyết định go hoặc no go
Tuần 4	Extension và backend kết nối end to end	Demo luồng cơ bản
Tuần 6	Transcript index, summary và chapter	Demo phân tích video
Tuần 8	Search và Ask Video có citation	MVP hoàn thành
Tuần 10	Notes, quiz, flashcard và history theo phạm vi	Feature complete
Tuần 12	Regression, security review, báo cáo và demo	Release candidate

17 Tài liệu tham khảo

Tài liệu nội bộ

- Tài liệu ý tưởng và yêu cầu YouTube Learning Companion.
- Kế hoạch dự án YouTube Learning Companion ngày 27/08/2026.
- Phân công và hướng dẫn công việc chi tiết ngày 28/08/2026.

Tài liệu kỹ thuật chính thức

- Gemini API OAuth <https://ai.google.dev/gemini-api/docs/oauth>
- Chrome Identity API <https://developer.chrome.com/docs/extensions/reference/api/identity>
- OAuth cho Chrome Extension <https://developer.chrome.com/docs/extensions/how-to/integrate/oauth>
- Chrome Cookies API <https://developer.chrome.com/docs/extensions/reference/api/cookies>
- Chrome Extension permissions <https://developer.chrome.com/docs/extensions/develop/concepts/declare-permissions>

Kết luận

Baseline này cho phép bốn thành viên phát triển song song dựa trên ranh giới module và schema đã xác định. Nhóm ưu tiên hoàn thành luồng đăng nhập, phân tích transcript, search và Ask Video có timestamp trước khi mở rộng sang quiz, flashcard và learning history. Ba thử nghiệm kỹ thuật của Sprint 1 là điều kiện bắt buộc để giữ hoặc thay đổi thiết kế OAuth, transcript và AI.